Axiora – Software Requirements Specification (SRS)

Version 1.0 · Owner: Founder & CEO · Audience: any developer or AI coding agent building the Axiora website and client platform

1. Purpose and Scope

Axiora is an AI-first software agency. Services: AI automation, Machine Learning, Deep Learning, Web Development, Full-Stack Development, App Development, and everything around applied AI (chatbots, RAG, agents, computer vision, NLP, MLOps, data pipelines).

This document defines the complete requirements for the **Axiora platform**: a public marketing website, a lead-capture and booking system, a client portal, and an admin back office. It is written so an agent can implement it phase by phase without further questions. Where a choice is open, the default stated here is the decision.

Out of scope for v1: online payments, multi-tenant SaaS billing, native mobile apps for the platform itself.

2. Business Goals

1. Look like a credible, established studio from day one (the company is new; trust signals matter more than anything).
2. Convert visitors into qualified leads (contact form, booking a call, project estimator).
3. Rank on Google for service + intent keywords (AI automation agency, custom AI development, etc.).
4. Give clients a private portal for proposals, project status, files and invoices (invoice upload only, no payments in v1).
5. Give the CEO a secure admin panel to manage leads, content and clients without touching code.
6. Be secure enough that no outsider can read leads, client files or admin data.

3. Users and Roles

Role	Description
Visitor	Anonymous public user
Client	Verified customer with portal access to own projects only
Staff	Team member; manages leads and assigned projects
Admin	Full content and user management
Owner (CEO)	Everything Admin can do, plus security settings, audit logs, role changes, data export/delete

Principle: **deny by default**. Every route and API call checks role and ownership on the server.

4. Functional Requirements

4.1 Public Website

- **FR-1 Home:** hero with clear value proposition, primary CTA (Book a call), service overview, proof section (process, tech stack, selected work), FAQ, final CTA.
- **FR-2 Services:** one page per service group: AI Automation, Machine Learning & Deep Learning, Generative AI and LLM Apps, Web and Full-Stack Development, Mobile App Development, Data and MLOps. Each has problem, approach, deliverables, tech, typical timeline, FAQ and CTA.
- **FR-3 Work / Case studies:** list and detail pages. Content: problem, solution, stack, outcome. Each item has a type label: *Client project* or *Founder project (pre-Axiora)*. Never present founder projects as client work.
- **FR-4 About:** story, principles, founder profile, how we work.
- **FR-5 Process:** discovery, proposal, build, launch, support.
- **FR-6 Blog / Insights:** MDX or CMS posts, categories, reading time, author, related posts, RSS, JSON-LD Article schema.
- **FR-7 Contact:** form (name, email, company optional, service interest, budget range, message, optional file ⩽ 5 MB), plus direct email and social links.

- **FR-8 Book a call:** embedded scheduler (Cal.com free or self-built slots) with timezone detection and confirmation email.
- **FR-9 Project estimator (optional, phase 2):** multi-step form producing a rough range; stores as a lead.
- **FR-10 Legal:** Privacy Policy, Terms, Cookie notice (consent banner only if non-essential cookies are used).
- **FR-11 Custom 404/500**, sitemap.xml, robots.txt, OG images per page.

4.2 Lead Management (Staff/Admin)

- **FR-20** Every form submission creates a Lead (status: New, Contacted, Qualified, Proposal Sent, Won, Lost).
- **FR-21** Lead list with search, filters, assignee, notes, activity timeline.
- **FR-22** Email notification to the team inbox on new lead; auto-reply to the sender.
- **FR-23** CSV export (Owner/Admin only, logged).
- **FR-24** Convert a Lead to a Client + Project in one action.

4.3 Client Portal

- **FR-30** Invite-only signup (email invite link, expiring in 72 h).
- **FR-31** Dashboard: active projects, milestones, status, next meeting.
- **FR-32** Project page: timeline, deliverables, shared files, comments thread.
- **FR-33** Proposals and contracts: view and download PDF, mark Accepted (records name, timestamp, IP).
- **FR-34** Invoices: view and download PDF uploaded by staff.
- **FR-35** Support requests / change requests tied to a project.
- **FR-36** Notification emails on new file, comment or milestone change.

4.4 Admin Back Office

- **FR-40** Manage users, roles, invitations; disable account.
- **FR-41** CMS for services, case studies, blog, FAQ, testimonials (testimonials require written client approval flag).
- **FR-42** Project and milestone management, file uploads, comments.
- **FR-43** Audit log viewer (who did what, when, from which IP).
- **FR-44** Site settings: contact email, social links, SEO defaults.

4.5 Marketing and Analytics

- **FR-50** Privacy-friendly analytics (Plausible, Umami or GA4 with consent).
- **FR-51** Google Search Console verification and sitemap submission.
- **FR-52** UTM capture on leads (source, medium, campaign).
- **FR-53** Structured data: Organization, Service, Article, FAQ, BreadcrumbList.

5. Authentication

- **AU-1** Email + password with Argon2id hashing, plus Google and GitHub OAuth. Staff, Admin and Owner **must** enable 2FA (TOTP); passkeys supported if library allows.
- **AU-2** Email verification required before any portal access.
- **AU-3** Password rules: min 12 chars, breached-password check (HIBP k-anonymity), no composition theatre.
- **AU-4** Sessions: HttpOnly, Secure, SameSite=Lax cookies; rotating session IDs; idle timeout 30 min for staff, 7 days for clients; absolute timeout 30 days; "sign out everywhere".
- **AU-5** Password reset: single-use, 30-minute tokens, hashed in DB, generic responses (no account enumeration).
- **AU-6** Account lockout / progressive delay after 5 failed attempts per account and per IP.
- **AU-7** Re-authentication required for sensitive actions (role change, data export, delete).

6. Authorization

- **AZ-1** RBAC plus ownership checks. Every query for client data is scoped by `clientId` derived from the session, never from request input.
- **AZ-2** Central policy module (`can(user, action, resource)`); no inline role checks scattered in handlers.
- **AZ-3** Protection against IDOR: use non-guessable IDs (UUIDv7/cuid2) and always verify ownership.

Capability	Visitor	Client	Staff	Admin	Owner
View public site	✓	✓	✓	✓	✓

Capability	Visitor	Client	Staff	Admin	Owner
Submit contact form	✓	✓	✓	✓	✓
View own projects/files		✓			
View all leads			✓	✓	✓
Manage assigned projects			✓	✓	✓
Manage CMS content				✓	✓
Manage users and roles				✓	✓
Export data, view audit log, security settings					✓

7. Security Requirements

7.1 Rate limiting (Redis-backed, e.g. Upstash; keyed by IP + account where applicable)

Endpoint	Limit
Login	5 / 15 min per IP+email
Signup / invite accept	5 / hour per IP
Password reset request	3 / hour per email, 10 / hour per IP
Contact / lead form	5 / hour per IP, plus Turnstile
File upload	20 / hour per user
General API	100 / min per user, 60 / min per anonymous IP
AI/LLM-backed endpoints (if any)	strict per-user daily quota

Return HTTP 429 with `Retry-After`. Log repeated violations; optional temporary IP ban.

7.2 SSRF guard

Any feature where the server fetches a URL that a user supplied (link previews, website audit tool, webhook delivery, image import) must go through **one** shared `safeFetch()` function that:

1. Allows only `http` and `https`, ports 80/443.

2. Resolves DNS itself and rejects loopback, private (10/8, 172.16/12, 192.168/16), link-local (169.254/16 including cloud metadata 169.254.169.254), CGNAT, multicast, and IPv6 equivalents (::1, fc00::/7, fe80::/10, IPv4-mapped).
3. Pins the resolved IP for the connection (defeats DNS rebinding) and re-validates on **every redirect**; max 3 redirects.
4. Enforces timeout (5 s), max response size (2 MB), and content-type allowlist.
5. Runs with no credentials or internal headers attached; egress allowlist where possible.
6. Never returns raw upstream error text to the user.

7.3 Application security (OWASP ASVS L2 target)

- **SEC-1** Validate all input on the server with a schema library (Zod); reject unknown fields.
- **SEC-2** Parameterized queries via ORM only; no string-built SQL.
- **SEC-3** Output encoding by default; sanitize any rich text/MDX (DOMPurify or allowlist); no `dangerouslySetInnerHTML` with user content.
- **SEC-4** CSRF protection on all state-changing requests (SameSite cookies + CSRF token or Origin check).
- **SEC-5** Security headers: strict CSP with nonces, HSTS (preload), X-Content-Type-Options, Referrer-Policy, Permissions-Policy, frame-ancestors 'none', COOP/CORP.
- **SEC-6** CORS: explicit origin allowlist; no wildcard with credentials.
- **SEC-7** Uploads: size and MIME allowlist, magic-byte check, random filenames, stored in private object storage, served by short-lived signed URLs, optional antivirus scan (ClamAV).
- **SEC-8** Secrets only in environment variables or a secrets manager; never in the repo; `.env` git-ignored; secret scanning on CI.
- **SEC-9** Encrypt data in transit (TLS 1.2+) and at rest; field-level encryption for sensitive fields (2FA secrets).
- **SEC-10** Audit log (append-only) for login, failed login, role change, export, delete, file access.
- **SEC-11** Bot protection: Cloudflare Turnstile on public forms, honeypot field, minimum submit time.
- **SEC-12** Dependency hygiene: Dependabot/Renovate, `npm audit` in CI, lockfile committed, pinned versions.

- **SEC-13** Error handling: generic messages to users, structured logs with request IDs, no stack traces in production.
- **SEC-14** Backups: daily automated DB backup, 30-day retention, restore test monthly.
- **SEC-15** Email security for the domain: SPF, DKIM, DMARC (start p=none, move to quarantine), MTA-STS optional.
- **SEC-16** Admin area on a separate path/subdomain, extra middleware, optional IP allowlist for Owner role.
- **SEC-17** Privacy: data retention policy, deletion on request, minimal PII, consent for marketing emails.
- **SEC-18** `security.txt` at `/.well-known/security.txt` with a reporting address.

8. Non-Functional Requirements

- **Performance:** Lighthouse ⩾ 95 (mobile) on Performance, Accessibility, Best Practices, SEO; LCP < 2.0 s, CLS < 0.05, INP < 200 ms.
- **Accessibility:** WCAG 2.2 AA, full keyboard navigation, visible focus, reduced-motion support.
- **SEO:** server-rendered pages, unique titles/descriptions, canonical URLs, clean slugs, hreflang if multilingual, image alt text.
- **Responsive:** 360 px to 1920 px+; mobile-first.
- **Availability:** target 99.9%; health endpoint and uptime monitor.
- **Browser support:** last 2 versions of Chrome, Safari, Firefox, Edge.
- **Internationalization:** English first; structure ready for Urdu (RTL) later.

9. Recommended Architecture and Stack

- **Frontend/Backend:** Next.js (App Router) + TypeScript (strict), Server Components, Server Actions with validation.
- **Styling:** Tailwind CSS with design tokens from the UI/UX document; shadcn/ui or Radix primitives, customized (do not ship defaults unchanged).
- **Database:** PostgreSQL (Neon or Supabase free tier) with Prisma or Drizzle; migrations in repo.
- **Auth:** Auth.js or Better Auth with Argon2id, TOTP; or Supabase Auth if chosen, with Row Level Security enabled.
- **Rate limiting/cache:** Upstash Redis.

- **Email:** transactional via Resend/Brevo/SMTP from the domain mailbox; templates with React Email.
- **Files:** Cloudflare R2 or Supabase Storage (private buckets).
- **CMS:** MDX in repo for blog; DB-backed admin for case studies and leads.
- **Hosting:** Vercel or Cloudflare in front; DNS and WAF on Cloudflare (free plan).
- **Observability:** Sentry (errors), Better Stack/UptimeRobot (uptime), structured logs.
- **CI/CD:** GitHub Actions: lint, typecheck, unit tests, e2e, audit, preview deploys.

10. Data Model (core entities)

User(id, email, passwordHash, role, emailVerifiedAt, totpSecretEnc, status, createdAt) · Session · Account(OAuth) · Invite(token hash, email, role, expiresAt) · Lead(id, name, email, company, service, budget, message, status, assigneeId, utm*, createdAt) · LeadNote · Client(id, name, company) · ClientMember(userId, clientId) · Project(id, clientId, name, status, startDate, dueDate) · Milestone · File(id, projectId, key, mime, size, uploadedBy) · Comment · Proposal(id, projectId, fileId, acceptedAt, acceptedBy, ip) · Invoice(file only) · CaseStudy · Post · Testimonial(approved flag) · AuditLog(id, actorId, action, entity, entityId, ip, userAgent, at) · SiteSetting.

All tables: `createdAt`, `updatedAt`; soft delete where legally needed.

11. API Surface (summary)

- `POST /api/contact`, `POST /api/booking`
- `POST /api/auth/*` (managed by auth library)
- `GET/POST /api/portal/projects`, `/api/portal/files` (signed upload and download URLs)
- `GET/POST/PATCH /api/admin/leads`, `/api/admin/users`, `/api/admin/content`
- `GET /api/health`

Every route: authentication → authorization → rate limit → validation → action → audit log → typed response. Consistent error shape `{ error: { code, message, requestId } }`.

12. Testing and Quality

- Unit tests for policy module, safeFetch, validators.
- Integration tests for auth flows and IDOR attempts (client A must never read client B).

- E2E (Playwright): contact form, login with 2FA, upload, role restrictions.
- Security checks: OWASP ZAP baseline scan, header check (securityheaders.com), SSL Labs.
- Accessibility: axe in CI.

13. Delivery Phases

1. **Phase 1 – Foundation and public site (week 1–3):** design system, pages, SEO, contact form with Turnstile, rate limiting, email, analytics, legal pages. **Go live, submit to Search Console.**
2. **Phase 2 – Auth and Admin (week 4–5):** auth, 2FA, RBAC, lead management, audit log, CMS.
3. **Phase 3 – Client portal (week 6–8):** invites, projects, files, proposals, comments.
4. **Phase 4 – Growth (ongoing):** blog cadence, case studies, estimator, booking, newsletter.

14. Launch and Marketing Checklist

1. Register domain, set SPF/DKIM/DMARC, create mailboxes (hello@, support@, security@).
2. Reserve the brand handle on LinkedIn, Instagram, Facebook, GitHub, X, YouTube (same handle everywhere).
3. Deploy site, verify Search Console, submit sitemap, create Google Business Profile if applicable.
4. Publish 3 case studies and 3 articles before promoting.
5. Then LinkedIn company page, then Instagram/Facebook, posting 2–3 times a week; run Google Ads only after the site converts organically.

15. Content Guidance: Portfolio Projects

Adding your earlier projects is **recommended**, because a new agency with zero work looks risky. Do it honestly: label them "Founder projects" or "Built by our founder", show real outcomes and tech, and never fake client names or testimonials. Replace them gradually with Axiora client work.

16. Acceptance Criteria (summary)

- All FR items for the phase work and have tests.
- No critical or high findings in ZAP baseline scan.
- A client cannot access another client's data by any URL or ID manipulation.
- Rate limits verified by automated test.
- SSRF test suite passes against private IPs, metadata IP, redirects and DNS rebinding cases.
- Lighthouse and accessibility targets met.
- Secrets absent from repo history.

17. Instructions to the Implementing Agent

- Implement phase by phase; do not skip security items to ship faster.
- Follow the UI/UX document exactly for tokens, components and copy tone.
- No placeholder lorem ipsum in production, no unexplained gradients or stock "AI glow" styling.
- Ask before adding any dependency not listed; keep the dependency count low.
- Provide a README with setup, env variables (names only), scripts, and a SECURITY.md.